

U.S. DEPARTMENT OF AGRICULTURE
WASHINGTON, D.C. 20250

DEPARTMENTAL REGULATION	NUMBER: DR 3530-004
SUBJECT: Firewall Security	DATE: June 9, 2026
OPI: Office of the Chief Information Officer, Cybersecurity and Privacy Operations Center	EXPIRATION DATE: June 9, 2031

<u>Section</u>	<u>Page</u>
1. Purpose	1
2. Scope	1
3. Special Instructions/Cancellations	2
4. Background	2
5. Policy	3
6. Roles and Responsibilities	3
7. Penalties and Disciplinary Actions for Noncompliance	5
8. Policy Exceptions	5
9. Inquiries	6
Appendix A – Acronyms and Abbreviations	A-1
Appendix B – Definitions	B-1
Appendix C – Authorities and References	C-1

1. PURPOSE

This Departmental Regulation (DR) establishes the parameters for firewall configuration and provides guidance for the development of associated processes and procedures within the United States Department of Agriculture (USDA).

Firewalls are a key component of the defense-in-depth security strategy for all information technology (IT) systems, networks, servers, and applications in USDA.

2. SCOPE

This policy applies to the USDA Enterprise perimeter, USDA managed data centers, Demilitarized Zone (DMZ), and cloud service gateways (CSG) to control data flow between

USDA and external entities.

3. SPECIAL INSTRUCTIONS/CANCELLATIONS

- a. This DR supersedes Departmental Manual (DM) 3530-004, *Firewall Technical Security Standards*, dated February 17, 2005.
- b. This DR is effective immediately when published and will remain in effect until it is superseded, or it expires.
- c. This DR addresses and meets the requirements of:
 - (1) the *Federal Information Security Modernization Act of 2014* (FISMA), [44 United States Code \(U.S.C.\) §§ 3551-3559](#);
 - (2) [DR 3185-004](#), *Enterprise Zero Trust Architecture*;
 - (3) [DR 3520-002](#), *Configuration Management*;
 - (4) [7 Code of Federal Regulations \(CFR\) § 2.32](#), *Chief Information Officer*;
 - (5) [44 U.S.C. § 3506\(b\)\(2\)](#), *Federal Agency Responsibilities*;
 - (6) National Institute of Standards and Technology (NIST), [Special Publication \(SP\) 800-53 Rev. 5](#), *Security and Privacy Controls for Information Systems and Organizations*; and
 - (7) NIST, [SP 800-41 Rev. 1](#), *Guidelines on Firewalls and Firewall Policy*.
- d. All USDA Mission Areas, agencies, and staff offices will align their USDA-supported firewall specifications and procedures with this DR within 6 months of the publication date.

4. BACKGROUND

- a. Information Security Modernization Act (FISMA) requires Federal agencies to use information security protections commensurate with the risk posed to Federal information and information systems. Firewalls are devices or programs that restrict or permit the flow of specific network traffic between networks or hosts. They allow for the enforcement of security postures across the enterprise computing environment. USDA is implementing an enterprise zero trust architecture (ZTA), and firewalls are just one layer of a multilayer security strategy.
- b. USDA follows the specific firewall standards established by NIST in SP 800-41 Revision 1. USDA refers to this guidance to implement all firewall standards.

- c. USDA uses Managed Trusted Internet Protocol Service (MTIPS) and CSG capabilities to connect USDANet to external networks operated by organizations other than USDA. This includes the cloud service providers (CSP) and commercial networks that remote employees use to access USDANet. There are multiple MTIPS and CSG locations which host firewalls and remote access services that protect the USDANet perimeter.

5. POLICY

- a. It is USDA policy that direct connection of agriculture networks, to or from the internet or extranet, must go through approved USDA firewalls.
- b. USDA IT resources must be protected from external threats using zero trust principles including micro-segmentation, policy enforcement points, continuous monitoring and threat detection or other USDA-approved DMZ network isolation protection methods.
- c. All USDA Mission Areas, agencies, and staff offices will only use USDA-supported firewalls. They will ensure USDA-supported firewalls operate according to USDA policies between external networks run by organizations other than the USDA and the USDA enterprise network.
- d. All USDA firewalls will be configured to comply with:
 - (1) [SP 800-41 Rev. 1](#), Guidelines on Firewalls and Firewall Policy;
 - (2) The applicable controls in [SP 800-53 Rev. 5](#) (specifically, Access Control (AC)-4 Information Flow Enforcement); and
 - (3) [DR 3505-003](#), *Access Control for Information and Information Systems*.

6. ROLES AND RESPONSIBILITIES

- a. The USDA Chief Information Security Officer (CISO) will create, implement, and verify adherence to cybersecurity policies.
- b. The USDA Office of the Chief Information Officer (OCIO) Digital Infrastructure Services Center (DISC) Network Enterprise Division Director will:
 - (1) Follow NIST's technical firewall standards for USDA's IT environment;
 - (2) Review and confirm that all USDA agency firewalls standards and protocols comply with this DR and USDA ZTA security controls;

- (3) Perform an annual review to find and remove any inactive or dormant firewall rules;
 - (4) Actively engage with the OCIO Configuration Control Board (CCB) in the preparation of exception packages, as required; and
 - (5) Coordinate with agencies or Mission Areas to promote and implement the defense-in-depth environment within USDA.
- c. The USDA Mission Area Assistant Chief Information Security Officers (ACISO) or USDA Mission Area Assistant Chief Information Officers (ACIO) will:
- (1) Ensure the provisions of this DR are implemented in all USDA agency or Mission Area IT environments;
 - (2) Oversee that all relevant USDA IT personnel are acquainted with the provisions of this DR placing particular emphasis on the Information Systems Security Manager (ISSM) and System/Network Administrators (SA/NA);
 - (3) Confirm that all USDA agency security plans and internal operating procedures include instructions for the secure use of approved firewall protocols;
 - (4) Confirm that all network traffic is denied unless explicitly allowed;
 - (5) Ensure that any changes made to firewall and gateway standards undergo review by the agency Configuration Control Board (CCB) and are approved by the Designated Approval Authority (DAA);
 - (6) Ensure that USDA agency personnel promptly respond to security alerts from firewalls;
 - (7) Prepare formal exception requests for firewalls that do not meet the requirements of this DR, in conformance with Section 8, *Policy Exceptions*; and
 - (8) Actively engage with the Associate CIO responsible for CSP to establish a defense-in-depth strategy to protect all of USDA's IT assets.
- d. The USDA Agency ISSMs will:
- (1) Include the requirements of this DR in USDA agency security plans and internal operating procedures to ensure secure use of approved firewall protocols and standards;
 - (2) Participate, via the USDA agency CCB, in the review of changes to firewalls standards;

- (3) In conjunction with the USDA agency SA/NA, ensure that all remote connections are centrally managed, and users of remote services are fully authenticated;
 - (4) In coordination with the USDA agency SA/NA, respond promptly to high-security alert notifications from firewalls, taking appropriate remedial action to protect USDA information assets;
 - (5) Conduct periodic reviews, at least quarterly, of all firewalls and gateways to determine compliance with protocols and standards; and
 - (6) Participate in the preparation of waiver packages, as required.
- e. USDA Agency SA/NAs will:
- (1) Include all standards and approved protocols in internal operating procedures for firewalls; and
 - (2) Promptly respond to high-security alert notifications from USDA agency firewalls and, in coordination with the ISSM, take appropriate remedial action to protect USDA information assets.

7. PENALTIES AND DISCIPLINARY ACTIONS FOR NONCOMPLIANCE

- a. [DR 4070-735-001](#), *Employee Responsibilities and Conduct, Section 16: Computers*, sets forth USDA-developed policies, procedures, and standards on employee responsibilities and conduct regarding the use of computers and telecommunication equipment. In addition, [DR 4070-735-001, Section 21: Disciplinary or Adverse Action](#), states:
 - (1) Any violation of the responsibilities or standards contained in this DR may be cause for disciplinary or adverse action; and
 - (2) Any disciplinary or adverse action taken will be consistent with the applicable laws and regulations.
- b. Such disciplinary or adverse action will be consistent with applicable laws and regulations such as Office of Personnel Management regulations, Office of Management and Budget (OMB) regulations, and the Office of Government Ethics, [5 CFR § 2635.101, et seq.](#), *Standards of Ethical Conduct for Employees of the Executive Branch*.

8. POLICY EXCEPTIONS

All Mission Areas, agencies, and staff offices will conform to this policy. Any Mission Area, agency, or staff office that cannot meet a specific policy requirement must request a policy exception.

9. INQUIRIES

Address inquiries concerning this DR to OCIO, CPOC via CPOC-CyberPolicy@usda.gov.

-END-

APPENDIX A

ACRONYMS AND ABBREVIATIONS

AC	Access Control
CCB	Configuration Control Board
CFR	Code of Federal Regulations
CIO	Chief Information Officer
CISO	Chief Information Security Officer
CPOC	Cybersecurity and Privacy Operations Center
CSG	Cloud Service Gateway
CSP	Cloud Service Providers
DAA	Designated Approval Authority
DISC	Digital Infrastructure Services Center
DM	Departmental Manual
DMZ	Demilitarized Zone
DR	Departmental Regulation
EIS	Enterprise Infrastructure Solutions
FISMA	Federal Information Security Modernization Act
GSA	General Services Administration
IETF	Internet Engineering Task Force
ISSM	Information Systems Security Manager
IT	Information Technology
NA	Network Administrator
NIST	National Institute of Standards and Technology
MTIPS	Managed Trusted Internet Protocol Service
OCIO	Office of the Chief Information Officer
OMB	Office of Management and Budget
OPI	Office of Primary Interest (also known as the policy owner or sponsor)
RAS	Remote Access Services
RFC	Request for Comments
SA	System Administrator
SA/NA	System/Network Administrator
SP	Special Publication
TIC	Trusted Internet Connections
USDA	United States Department of Agriculture
ZTA	Zero Trust Architecture

APPENDIX B

DEFINITIONS

Configuration Control Board (CCB). A group of qualified people with responsibility for the process of regulating and approving changes to hardware, firmware, software, and documentation throughout the development and operational life cycle of an information system. (Source: NIST, [SP 800-128](#), *Guide for Security-Focused Configuration Management of Information Systems*)

Defense-in-Depth Strategy. An information security strategy that integrates people, technology, and operations capabilities to establish variable barriers across multiple layers and missions of the organization. (Source: NIST [SP 800-53](#), Revision 5)

Demilitarized Zone (DMZ). An interface on a routing firewall that is similar to the interfaces found on the firewall's protected side. Traffic moving between the DMZ and other interfaces on the protected side of the firewall still goes through the firewall and can have firewall protection policies applied. (Sources: NIST, [SP 1800-21C](#), *Mobile Device Security: Corporate-Owned Personally-Enabled (COPE)*; NIST, [SP 800-41](#), Revision 1)

Designated Approval Authority (DAA). Official with the authority to formally assume responsibility for operating a system at an acceptable level of risk. This term is synonymous with authorizing official, designated accrediting authority, and delegated accrediting authority. (Source: Committee on National Security Systems (CNSSI), [Glossary](#))

Enterprise Zero Trust Architecture (Enterprise ZTA). Provides a collection of concepts designed to minimize uncertainty in enforcing accurate, least privilege per-request access decisions in information systems and services in the face of a network viewed as contested. (Source: NIST, [CSWP 20](#), *Planning for a Zero Trust Architecture*)

Firewall. An inter-network gateway that restricts data communication traffic to and from one of the connected networks (the one said to be "inside" the firewall) and thus protects that network's system resources against threats from the other network (the one that is said to be "outside" the firewall). (Source: NIST, [SP 800-82r3](#), *Guide to Operational Technology (OT) Security*)

Gateway. An intermediate system (interface, relay) that attaches to two (or more) computer networks that have similar functions but dissimilar implementations and that enables either one-way or two-way communication between the networks.

Managed Trusted Internet Protocol Service. Services under GSA's Enterprise Infrastructure Solutions (EIS) contract vehicle that provide TIC solutions to government clients as a managed security service. (Source: [CISA Trusted Internet Connections \(TIC\) 3.0](#))

Remote Access. The ability for an organization's users to access its non-public computing resources from external locations other than the organization's facilities. (Source: [NIST SP](#)

[800-46](#), Revision 2, Guide to Enterprise Telework, Remote Access, and Bring Your Own Device (BYOD) Security)

APPENDIX C
AUTHORITIES AND REFERENCES

[7 CFR § 2.32](#), *Chief Information Officer*

[44 U.S.C. § 3506\(b\)\(2\)](#), *Federal Agency Responsibilities*

Cybersecurity & Infrastructure Security Agency, [Trusted Internet Connections \(TIC\)](#) web page

Department of Homeland Security, [Trusted Internet Connections \(TIC\) Reference Architecture Document, Version 2.2](#), June 19, 2017

Federal Information Security Modernization Act of 2014 (FISMA), [44 U.S.C. §§ 3551-3559](#)

FIPS PUB, [140-3](#), *Security Requirements for Cryptographic Modules*, March 22, 2019

FIPS PUB, [186-5](#), *Digital Signature Standard (DSS)*, February 3, 2023

Internet Engineering Task Force (IETF), [Request for Comments \(RFC\) 6303](#), *Locally Served DNS Zones*, July 2011

IETF, [RFC 6761](#), *Special-Use Domain Names*, February 2013

NIST, [SP 800-41](#), Revision 1, *Guidelines on Firewalls and Firewall Policy*, September 2009

NIST, [SP 800-46](#), Revision 2, *Guide to Enterprise Telework, Remote Access, and Bring Your Own Device (BYOD) Security*, July 2016

NIST, [SP 800-53](#), Revision 5, *Security and Privacy Controls for Information Systems and Organizations*, September 2020, includes updates as of December 10, 2020

NIST, [SP 800-57](#), Revision 1, *Recommendation for Key Management, Part 3: Application-Specific Key Management Guidance*, January 2015

NIST, [SP 800-81-2](#), *Secure Domain Name System (DNS) Deployment Guide*, September 2013

NIST, [SP 800-128](#), *Guide for Security-Focused Configuration Management of Information Systems*, August 2011, includes updates as of October 10, 2019

Office of Government Ethics, [5 CFR § 2635.101, et seq.](#), *Standards of Ethical Conduct for Employees of the Executive Branch*

OMB, Circular [A-130](#), Appendix III, *Security of Federal Automated Information Resources*,

November 2000

OMB, Circular [A-130](#), Appendix IV, *Analysis of Key Sections*, November 2000

OMB, Circular [M-08-23](#), *Securing the Federal Government's Domain Name System Infrastructure*, August 22, 2008

USDA, [DR 3185-004](#), *Enterprise Zero Trust Architecture*, September 9, 2024

USDA, [DR 3505-003](#), *Access Control for Information and Information Systems*, July 17, 2019

USDA, [DR 3520-002](#), *Configuration Management*, July 17, 2019